



CITS2006 - Defensive Cybersecurity

Task 2 Report

Enhancing security in the community

Unit Name	CITS2006 - Defensive Cybersecurity
Assessment	Task 2: Enhancing security in the community
Group Members	Faiyaz Kabir Muhammad Afridi Ismail Charlie Yin Casey Zhu Tom Jowett
Student IDs	24773532 24445737 23497868 24722864 24833608
Date	15/05/2026

Project Summary Video: <https://www.youtube.com/watch?v=QjwYlde1N8A>

Member	Contribution
Faiyaz Kabir	- Implemented the IDS detection and response section of the project (2.4); - Built a local IDS simulation using Kali Linux as the suspicious source and Ubuntu as the simulated POS/IDS host; - Configured Suricata IDS with custom "BOBA ALERT" rules for ICMP probing, HTTP access, SSH attempts, and SMB-style access attempts; - Generated controlled test traffic from Kali, including ping probing, Nmap scans, HTTP access, and unauthorised SSH attempts; - Collected IDS evidence from Suricata fast.log and eve.json outputs; - Implemented the response step by blocking the suspicious intruder's source IP using UFW firewall rules. - Wrote the IDS simulation, detection workflow, response workflow, evidence matrix, limitations, and practical deployment recommendation sections.
Muhammad Afridi Ismail	- Implemented the Section 2.1: <i>Prevent Initial Access</i> control part of the project. - Conducted initial port scanning to identify exposed services (HTTP/HTTPS and related ports). - Disabled UPnP and reviewed firewall settings to prevent unauthorised port exposure. - Performed post-implementation validation to confirm no additional ports were exposed. - Designed and implemented guest WiFi network segmentation to isolate users from internal resources. - Tested and verified restricted access to internal systems from the guest network. - Demonstrated gateway access limitation using endpoint-level routing control for security validation. - Configured Windows device-level protections including enforced screen lock and session control. - Implemented USB access restriction to prevent malware introduction via removable media. - Documented implementation process, testing results, limitations and security impact of applied controls.
Charlie Yin	- Conducted original store investigation; - Developed overall threat model; - Designed layered mitigation strategy; - Proposed the overall implementation strategy; - Restructured and integrated sections into a coherent report; - Aligned practical solutions with real-world business constraints; - Edited and refined inconsistent sections; - Wrote the Introduction, Justification, Impact, Conclusion and Reflection sections, excluding Section 2. - Prepared an owner-friendly security recommendation summary and contacted the store owner; - Ensured recommendations matched the observed environment and realistic attack paths.
Casey Zhu	- Edited a 1-minute project presentation video. - Completed Section 2.3 of the project report, focusing on network access control and protection of critical systems. - Designed VLAN-based network segmentation for the shop network. - Separated devices into different trust zones based on their roles and risk levels. - Created firewall and ACL rules to restrict unnecessary inter-VLAN access. - Added host-level protection rules for the POS Server and NVR. - Planned VPN-based remote access for the manager with limited access to approved internal systems. - Included logging rules for suspicious traffic, failed access attempts, and denied inter-VLAN connections.
Tom Jowett	- Completed Section 2.2 as described below, focusing on prevention of lateral movement - Built a simulation network corresponding to the implemented network design using CISCO packet tracer - Segregated the network into multiple VLANs based on trust level and business function - Tested whether each device can communicate with others within the VLAN - Tested whether devices on one VLAN can't communicate with those in another VLAN - Explored the security issues of the flat network - Discussed the impact and reasoning for the VLAN implementation - Compiled and edited demo presentation

Introduction

This project analyses the security posture of Taning Lemon Tea Perth, a small community business with a network environment that includes Point-of-Sale systems, Surveillance Infrastructure, staff WiFi and network management interfaces. The purpose of this report is to identify realistic attack paths through threat modelling and propose practical, layered security controls to reduce risk.

1.1 Threat modeling

Identify Core Assets:

- Zii POS Server (handles payment data)
- Dahua NVR (surveillance system)
- Router Management Interface (network control)

Identify Threat Actors:

- Internal users (employees)
- External attackers (internet-based hackers)
- Opportunistic scanners (automated bots)

Identify Attack Surface:

- WiFi network access
- Router admin interface (192.168.1.1)
- Public IP exposure (insecure port forwarding setting / UPnP)

Attack Path 1: WiFi → Router Compromise

1. Employee connects to WiFi
2. Access router admin interface (192.168.1.1)
3. Use default/weak credentials
4. Gain admin access
5. Modify network settings → full control

Attack Path 2: External → NVR Exploitation

1. Attacker scans public IP
2. Detect open port 37777 (UPnP)
3. Identify Dahua NVR service
4. Exploit known vulnerabilities
5. Gain remote access

1.2 Solution Proposal

The proposed solutions aim to mitigate the identified attack paths by applying practical security controls at different stages of the attack chain. These controls focus on preventing initial access, limiting lateral movement, protecting critical systems, and improving lightweight detection and response, thereby reducing both the likelihood and impact of successful attacks in a small business environment.

Security Enhancements / Implementation

2.1 Prevent Initial Access

2.1.1 Reduce external attack surface

To reduce the external attack surface, a practical assessment of exposed services on the public IP address was conducted using Nmap.

The scan results identified that only web-related ports were accessible:

```
PORT      STATE SERVICE      VERSION
80/tcp    open  http         Cloudflare http proxy
443/tcp   open  ssl/https    cloudflare
8080/tcp  open  http         Cloudflare http proxy
8443/tcp  open  ssl/https-alt cloudflare
```

Figure 1. Example of open ports that are protected by Cloudflare Proxy

These open port services were protected by Cloudflare Proxy Infrastructure indicating that no direct internal services were exposed to the internet.

Additionally, the router configuration was reviewed and hardened. Universal Plug and Play (UPnP), which was enabled by default, was manually disabled through the router administration interface. This prevents internal devices from automatically opening ports without administrative approval.

Internet Access Control	Port Forwarding	Firewall	Enable DMZ
Port Forwarding			
NAT Enable		☒ ON	
Enable UPnP IGD		☐ OFF	
Advertisement period		1800	
Advertisement TTL		4	
UPNP IGD allows games, peer-to-peer, remote assistance or other applications to automatically create port forwarding rules. This option can create a risk for the security of your local network, check list of rules in table below. Note: This feature can only be used if your modem has been configured with a public WAN IP address.			
Add rules manually			
Custom service name			
Service	Others	Protocol	TCP+UDP
External host		External port	
Internal host		Internal port	
		Add	
		Clear	

Figure 2. Example of disable UPnP in router setting

2.1.2 Isolate Guest WiFi from Internal Network

As Taning Lemon Tea is a small community business using a consumer-grade router rather than enterprise networking equipment, Guest WiFi isolation provides a practical and low-cost method for separating higher-risk devices such as staff personal phones and delivery service tablets from critical business systems.

	2.4GHz	5GHz
Enable Guest Wi-Fi	☒	☒
Wi-Fi name (SSID) 3-32 characters	Guest_wifi	Guest_wifi_5GHz
Hide Guest Wi-Fi name (SSID)	☐	☐
Wi-Fi security	WPA2-PSK/WPA3-PSK	WPA2-PSK/WPA3-PSK
Wi-Fi password	*****	*****
	Show Password ☐	Show Password ☐
Confirm password	*****	*****

Figure 3. Example of enable guest WiFi in router setting

The router's built-in isolation feature ensures that devices connected to the Guest WiFi are restricted to internet-only access and are unable to communicate with internal devices or access the router interface.

To validate this configuration, a test was conducted by connecting a mobile device to the Guest WiFi network and attempting to access the router gateway (192.168.1.1). The connection was unsuccessful, confirming that internal network access was effectively blocked.

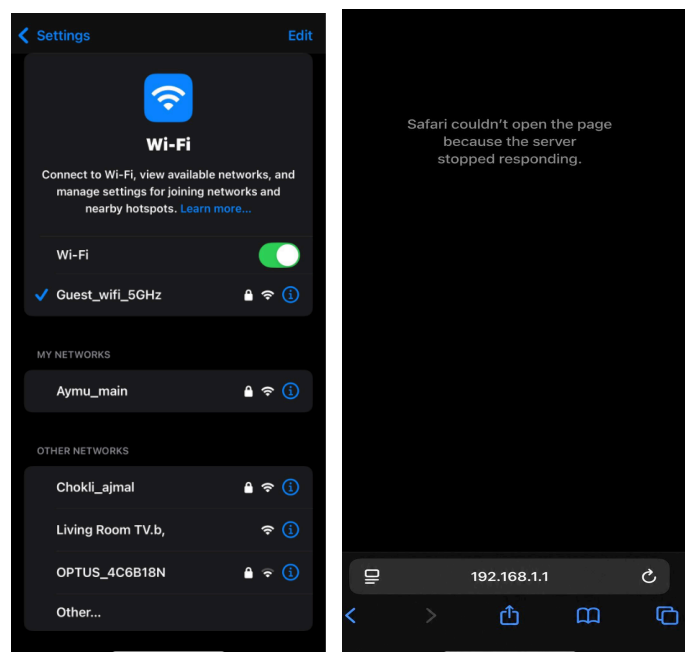


Figure 4. Guest Wi-Fi device unable to access the internal router gateway

2.1.3 Reduce Device-Level Attack Surface

To prevent unauthorized access to unattended systems, automatic screen locking was configured on Windows-based monitoring computers.

System settings were modified to ensure that devices enter sleep mode after **2 minutes of inactivity**, and users are required to authenticate upon resuming the session. Additionally, the “On resume, display logon screen” setting was enabled to enforce login requirements.

This configuration ensures that systems are not left accessible when unattended, particularly in shared environments such as staff rooms in Taning Lemon Tea.

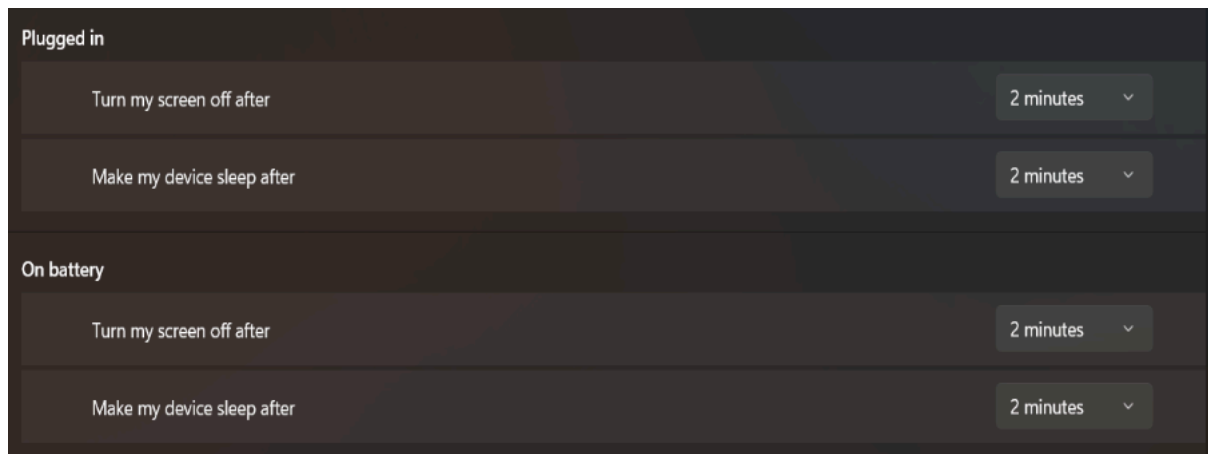


Figure 5. Windows sleep timeout configuration

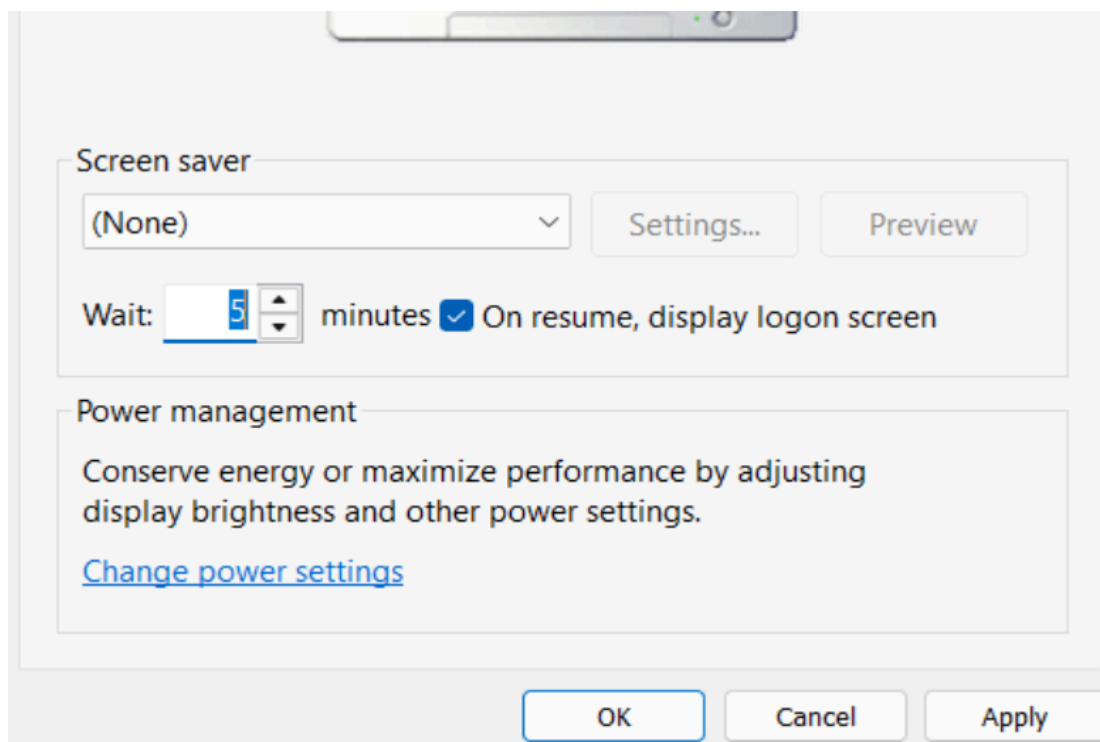


Figure 6. Screen saver lock-on-resume configuration

Also to reduce the risk of malware introduction through removable media, USB access restrictions were implemented by modifying the Windows system registry.

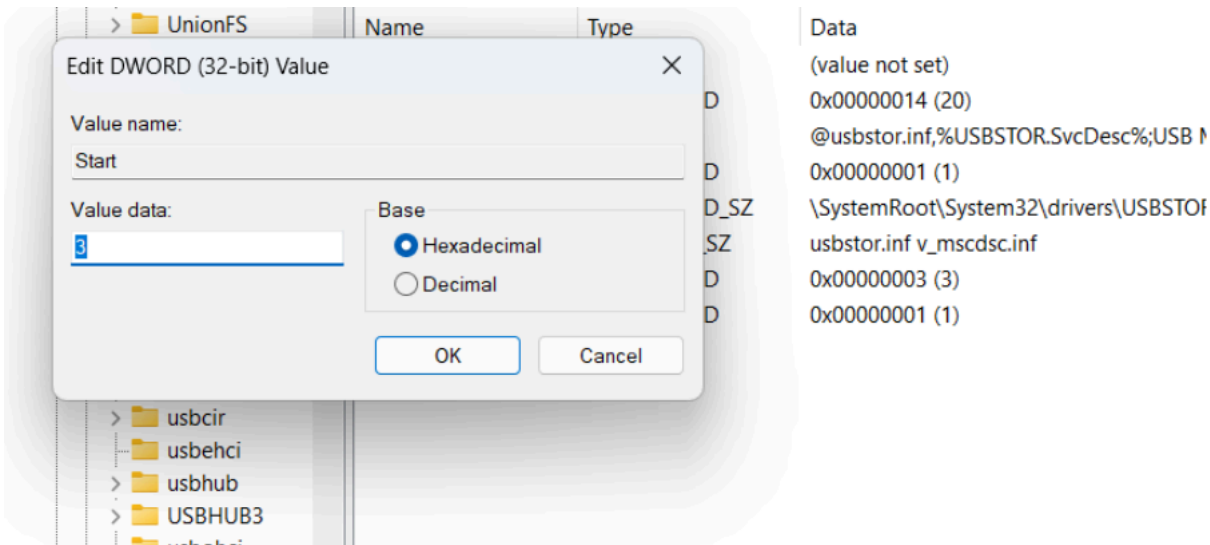


Figure 7. Modification of Windows Registry to configure USB storage driver settings as part of implementing removable media access control.

The USB storage driver was disabled by configuring the following registry setting:
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\USBSTOR Start = 4

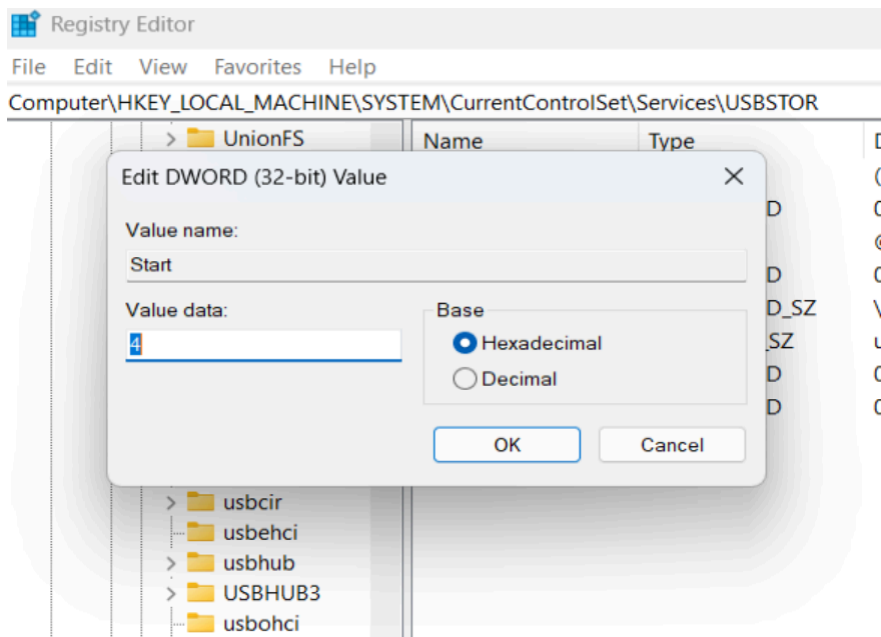


Figure 8. USB storage access disabled by setting the USBSTOR service value to “4” in the Windows Registry, preventing use of external storage devices.

This configuration prevents the USB storage driver from loading, thereby blocking the system from recognizing and mounting USB storage devices. A practical test was conducted by inserting a USB device into the system after applying the restriction. The device did not appear in Disk Management, indicating that the USB storage driver was successfully disabled and the device could not be accessed.

2.2 Prevent Internal Spread

2.2.1 Introduce VLAN

VLAN segmentation is used to separate devices based on trust level and business function. In this case, POS, CCTV, IoT, staff, and delivery devices are placed into separate VLANs so that compromise of one group does not automatically expose the rest of the network. Inter-VLAN traffic must pass through the router, where firewall rules can be applied to restrict unnecessary communication.

The implementation of a VLAN involves clustering inter-reliant systems together and then partitioning the network. Afterwards, each frame sent within the network (through a trunk link) has a VLAN tag in the header, which the switch uses to direct the traffic only to devices of the same VLAN. If data is needed to be sent between VLANs, it must pass through the router or a layer 3 switch, allowing for firewall or other controls.

2.2.2 Design VLAN

Before Network Topology Graph:

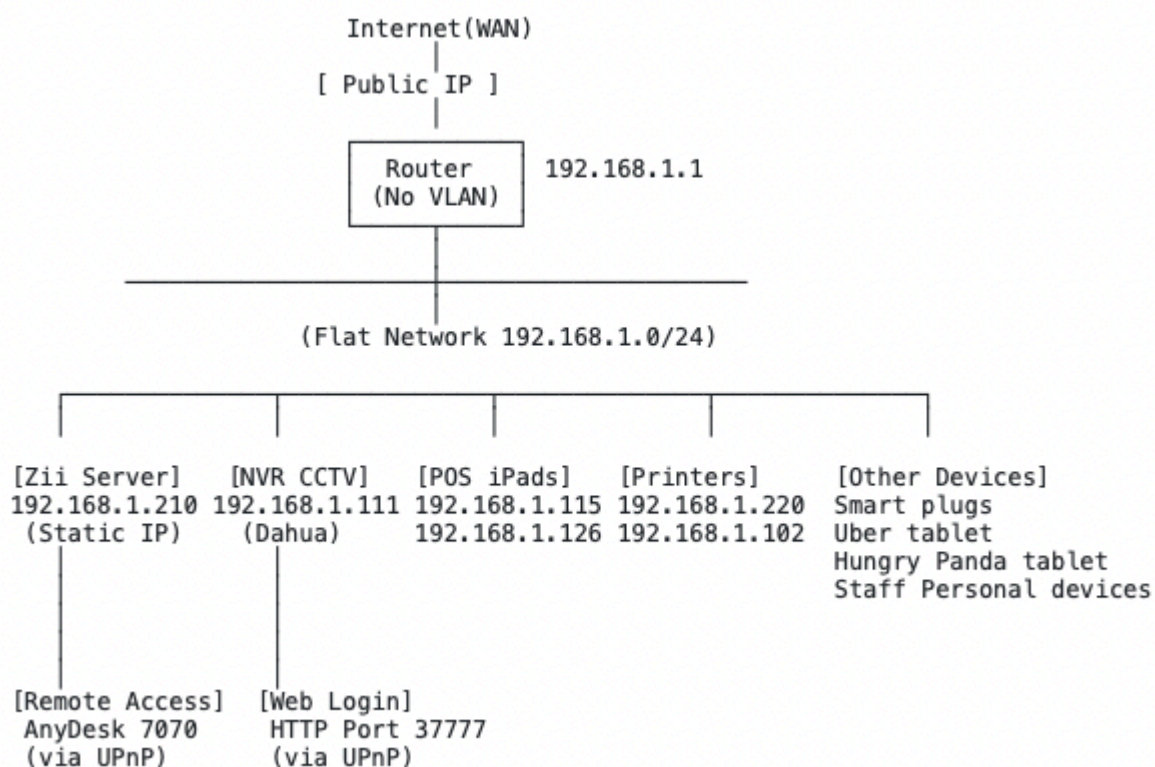


Figure 9. Original flat network layout

After VLAN Network Topology Graph:

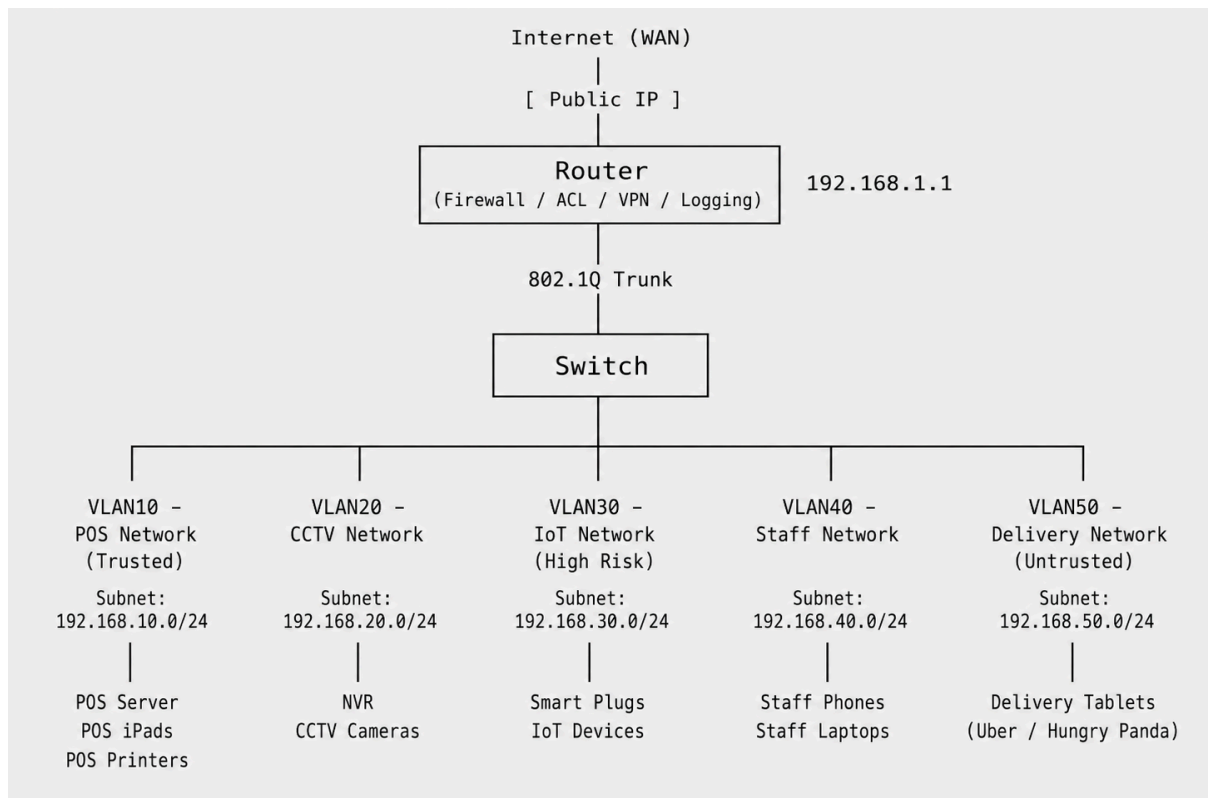
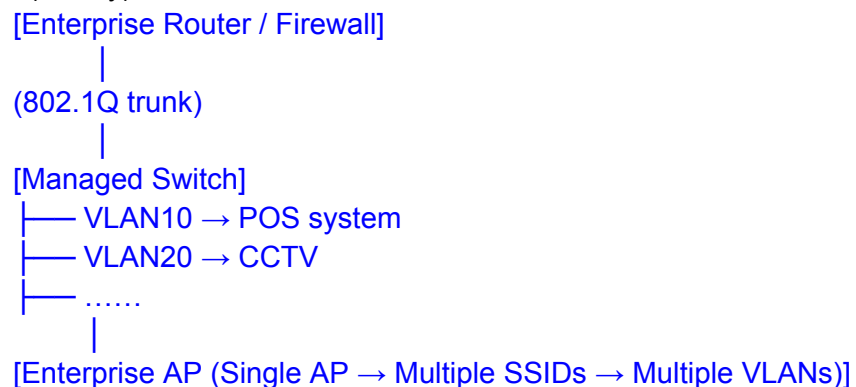


Figure 10. New segregated network layout

For our system in particular, all POS devices must be connected and therefore on the same VLAN. The NVR and CCTV cameras are also constantly communicating, requiring them to share a VLAN. Smart plugs and other IOT devices are a potentially risky attack surface, and largely independent, so keeping them isolated will limit the pivoting potential of any attacks through them. The staff's personal devices don't need access to the traffic from the rest of the network, blocking their access to the rest of the network while still providing internet access should keep usability intact without allowing for an attack surface. Lastly the ordering devices should be kept separate as the public has access to them, and any actions taken on them should be passed through a firewall to prevent any injection style attacks or to safeguard against access being obtained at this stage.

2.2.3 Practical Real-World Deployment Options

- Option1 (Ideally):



- Option 2 (Low-cost / High Technical):
 - [Soft Router (pfSense / OpenWRT)]
 - (802.1Q trunk)
 - [Managed Switch]
 - VLAN10 → POS server (critical)
 - VLAN20 → CCTV
 -
 - [One AP per VLAN (Multiple APs → Each AP = One network)]

2.2.4 Simulation VLAN on CISCO Packet Tracer

The first part of the setup is to allocate the VLANs and give them their names, this is initially done on the switch, as shown below.

```
Switch#configure terminal
Enter configuration commands, one per line. End with CNTL/Z.
Switch(config)#vlan 10
Switch(config-vlan)#name POS
Switch(config-vlan)#vlan 20
Switch(config-vlan)#name CCTV
Switch(config-vlan)#vlan 30
Switch(config-vlan)#name IoT
Switch(config-vlan)#vlan 40
Switch(config-vlan)#name Staff
Switch(config-vlan)#vlan 50
Switch(config-vlan)#name Delivery
Switch(config-vlan)#exit
Switch(config)#do show vlan brief
```

VLAN	Name	Status	Ports
1	default	active	Fa0/1, Fa0/2, Fa0/3, Fa0/4 Fa0/5, Fa0/6, Fa0/7, Fa0/8 Fa0/9, Fa0/10, Fa0/11, Fa0/12 Fa0/13, Fa0/14, Fa0/15, Fa0/16 Fa0/17, Fa0/18, Fa0/19, Fa0/20 Fa0/21, Fa0/22, Fa0/23, Fa0/24 Gig0/1, Gig0/2
10	POS	active	
20	CCTV	active	
30	IoT	active	
40	Staff	active	
50	Delivery	active	
1002	fddi-default	active	
1003	token-ring-default	active	
1004	fddinet-default	active	
1005	trnet-default	active	

```
Switch(config)#
```

Figure 11. VLAN labelling setup on switch

Following this, the network needs to be constructed fully if not done so already (if implementing this in the store, nothing should need to be done in this step). Below is a model of the network, each outside cluster represents one VLAN, and is scalable.

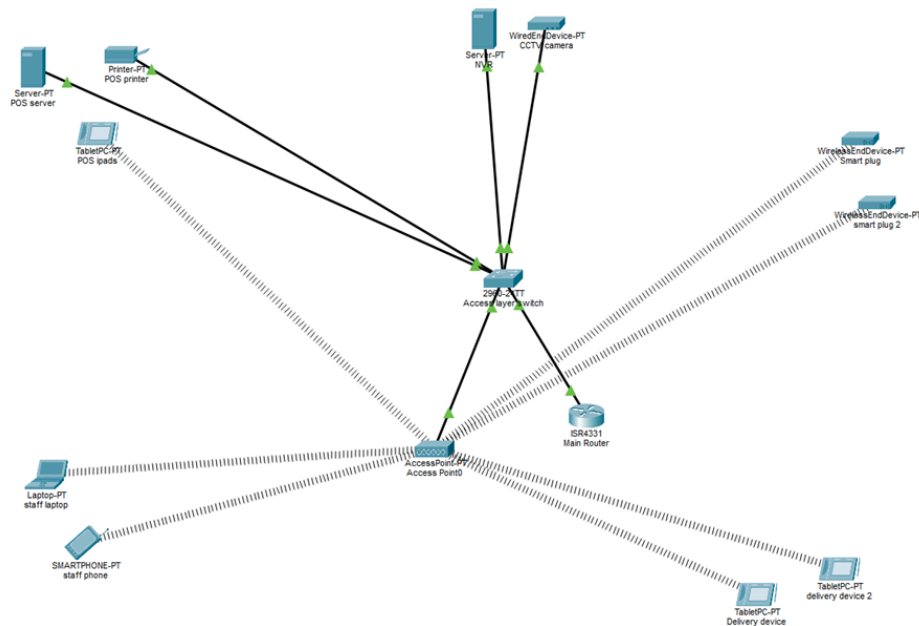


Figure 12. Virtual network simulation, end devices on edges, separated into VLAN groups

Once all physically connected devices are added, the switch will need to know which devices (ie which ports) belong to which VLAN, done in the second step. Additionally, the ports for the access point and router (gig0/1 and gig0/2 respectively) need to be configured as trunk ports, allowing for traffic from multiple VLANs to traverse a single physical link and be allocated correctly using 802.1Q tagging.

```
Switch(config)#interface fa0/1
Switch(config-if)#switchport mode access
Switch(config-if)#switchport access vlan 20
Switch(config-if)#exit
Switch(config)#interface fa0/2
Switch(config-if)#switchport mode access
Switch(config-if)#switchport access vlan 10
Switch(config-if)#exit
Switch(config)#interface fa0/3
Switch(config-if)#switchport mode access
Switch(config-if)#switchport access vlan 10
Switch(config-if)#exit
Switch(config)#interface fa0/4
Switch(config-if)#switchport mode access
Switch(config-if)#switchport access vlan 20
Switch(config-if)#exit
Switch(config)#interface gig0/1
Switch(config-if)#switchport mode trunk
Switch(config-if)#exit
Switch(config)#interface gig0/2
Switch(config-if)#switchport mode trunk
Switch(config-if)#exit
Switch(config)#do show vlan brief
```

VLAN Name	Status	Ports
1 default	active	Fa0/5, Fa0/6, Fa0/7, Fa0/8 Fa0/9, Fa0/10, Fa0/11, Fa0/12 Fa0/13, Fa0/14, Fa0/15, Fa0/16 Fa0/17, Fa0/18, Fa0/19, Fa0/20 Fa0/21, Fa0/22, Fa0/23, Fa0/24 Gig0/2
10 POS	active	Fa0/2, Fa0/3
20 CCTV	active	Fa0/1, Fa0/4
30 TAT	active	

Figure 13. Physically wired end devices mapped to corresponding VLANs

Next, the interface is turned on, and the VLANs are mapped to the corresponding addresses, shown below is VLAN 30. This is achieved by dividing the Gig0/0/0 interface into multiple sub-interfaces, each corresponding to one VLAN, allowing all inter-VLAN communication to be controlled centrally by the router.

```
Router(config)#interface gig0/0/0
Router(config-if)#no shutdown

Router(config-if)#
%LINK-5-CHANGED: Interface GigabitEthernet0/0/0, changed state to up

%LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet0/0/0, changed state to up

Router(config-if)#exit
```

Figure 14. Turning on the router

```
Router(config)#interface gig0/0/0.30
Router(config-subif)#
%LINK-3-UPDOWN: Interface GigabitEthernet0/0/0.30, changed state to down

%LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet0/0/0.30, changed state to up

Router(config-subif)#encapsulation dot1q 30
Router(config-subif)#ip address 192.168.30.1 255.255.255.0
Router(config-subif)#exit
```

Figure 15. Making the sub-interface for VLAN 30

```
Router(config)#do show ip interface brief
```

Interface	IP-Address	OK?	Method	Status	Protocol
GigabitEthernet0/0/0	unassigned	YES	unset	up	up
GigabitEthernet0/0/0.10	192.168.10.1	YES	manual	up	up
GigabitEthernet0/0/0.20	192.168.20.1	YES	manual	up	up
GigabitEthernet0/0/0.30	192.168.30.1	YES	manual	up	up
GigabitEthernet0/0/0.40	192.168.40.1	YES	manual	up	up
GigabitEthernet0/0/0.50	192.168.50.1	YES	manual	up	up
GigabitEthernet0/0/1	unassigned	YES	unset	administratively down	down
GigabitEthernet0/0/2	unassigned	YES	unset	administratively down	down
Vlan1	unassigned	YES	unset	administratively down	down

Figure 16. The sub-interfaces shown after all being configured

Lastly, on each device, the IP addresses need to be changed to fit the VLAN they are supposed to be on.

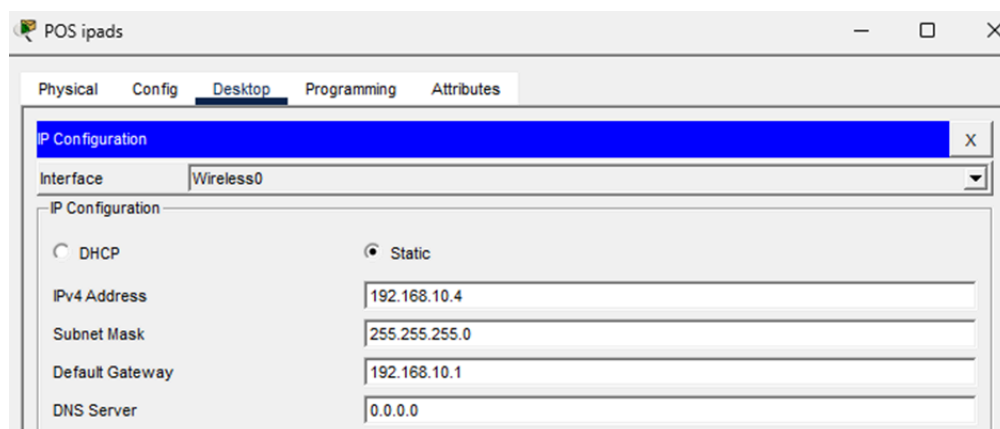


Figure 17. POS ipad ip address, subnet mask and default gateway

Now that this has been completed, ping tests can be run to test the connectivity of nodes to other nodes. Below, the staff laptop (VLAN 40) is unable to send and receive data to and from the POS server (192.168.10.2) but can communicate with the staff phone (192.168.40.3) as is expected. The behaviour is continued for all other VLANs and devices.

2.3 Restrict Access to Critical Systems

2.3.1 ACL in VLAN

Since the VLAN design already groups devices according to required communication, most VLANs can be treated as **isolated zones**. ACLs are then used to deny inter-VLAN traffic by default and permit only a small number of business-required exceptions. This section presents an access control list (ACL) design using five VLANs: VLAN10 for POS, VLAN20 for CCTV, VLAN30 for IoT, VLAN40 for Staff, and VLAN50 for Delivery devices. The goal is to replace flat-network risk with enforceable boundaries that protect payment systems, reduce lateral movement, and still allow day-to-day operations with minimal complexity.

2.3.2 ACL Design Principles

ACLs should follow three principles. First, inter-VLAN traffic should be denied by default. Second, only business-needed exceptions should be allowed. Third, higher-risk networks such as IoT and Delivery should never be permitted to initiate access toward higher-trust networks such as POS or Staff unless a documented exception exists.

The recommended design is to place all inter-VLAN routing on the router or firewall and make that device the single policy enforcement point. The switch should carry VLANs over an 802.1Q trunk, while the router or firewall applies ACLs, NAT, VPN policy, and logging. This keeps the design simple and avoids relying on VLAN separation alone as the security control.

2.3.3 Design ACL for VLAN

Source VLAN	Destination	Policy	Rationale
VLAN10 POS	POS Server, POS printers, payment/update services, approved DNS/NTP	Allow required traffic only; deny unsolicited access from other VLANs	Supports payment operations while protecting the most sensitive segment
VLAN10 POS	VLAN20, VLAN30, VLAN40, VLAN50	Deny by default; allow only documented admin exceptions	Prevents lateral movement into payment systems
VLAN20 CCTV	Cameras to NVR, approved DNS/NTP	Allow camera-to-NVR traffic only	Cameras need recorder access, not broad internal access

VLAN20 CCTV	Internet and other VLANs	Deny except documented firmware/update exceptions	Limits abuse of embedded camera devices
VLAN30 IoT	Approved controller/vendor services, approved DNS/NTP	Allow required outbound traffic only	Lets IoT function without creating internal attack paths
VLAN30 IoT	VLAN10, VLAN20, VLAN40, VLAN50	Deny	Treats IoT as high-risk and prevents lateral movement
VLAN40 Staff	Internet, NVR, optional POS management, approved DNS/NTP	Allow only justified business traffic by destination and port	Staff need limited business access, not unrestricted inter-VLAN access
VLAN50 Delivery	Internet, approved DNS/NTP	Allow outbound Internet only	Delivery devices are guest-like and third-party controlled
VLAN50 Delivery	All internal VLANs	Deny and log	Simplest and safest policy for untrusted delivery tablets

2.3.4 Host-Level Protection

Host-level protection should be deployed on the POS Server and NVR to provide an extra layer of defence beyond VLAN firewall rules. This ensures that even if network access controls are bypassed or misconfigured, the critical systems still restrict unauthorised traffic.

The POS Server should only allow traffic from approved POS devices, authorised management devices, and cloud POS services. Unnecessary or insecure protocols such as Telnet, FTP, SMB file sharing, unauthorised Remote Desktop, VNC, and unknown database connections should be blocked.

The NVR should only allow traffic from CCTV cameras, approved staff viewing devices, and VPN-based administrators. Insecure protocols such as Telnet, FTP, SMB, unauthorised SSH, HTTP administration, Remote Desktop, and VNC should also be blocked.

Both systems should block suspicious behaviours such as port scanning, repeated failed logins, brute-force attempts, access to unused services, and unexpected outbound connections. Security logs should be enabled to record blocked traffic and unauthorised access attempts for review.

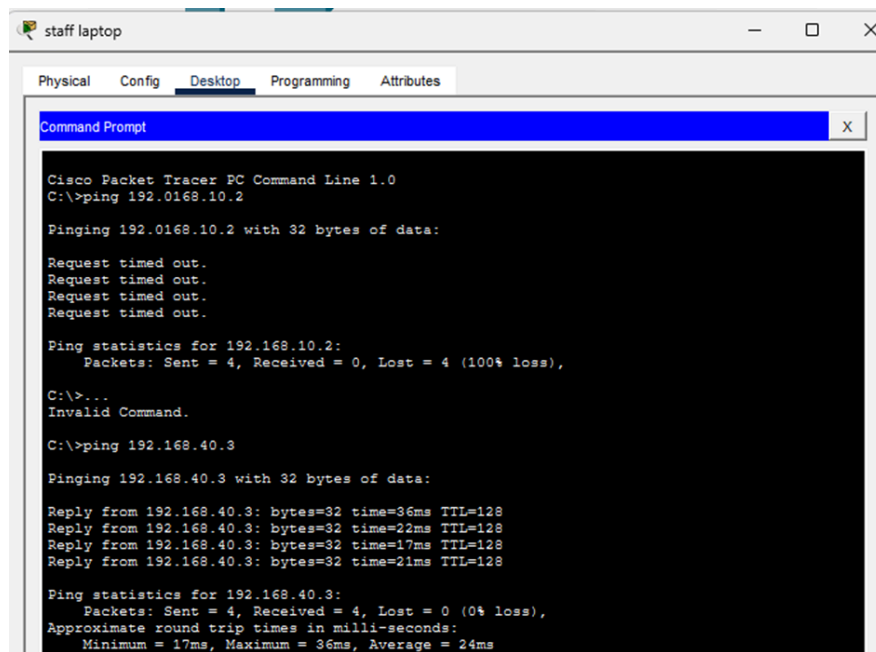


Figure 18. Staff laptop successfully connecting to device on same VLAN, and failing for device on different VLAN

2.3.5 VPN for Remote Management

A VPN should be used for remote management instead of exposing internal services such as the POS Server or NVR directly to the Internet. In this design, the manager connects to the store network through a remote-access VPN hosted on the router or firewall. After authentication, the manager's device is placed into a dedicated VPN management subnet.

The simplest topology is:

- Manager device on the Internet.
- Remote-access VPN tunnel to the shop firewall.
- VPN users placed into a dedicated VPN subnet or management zone.
- ACLs that permit the VPN subnet to reach only the POS Server in VLAN10 and the NVR in VLAN20 on approved ports, with all other internal access denied and logged.

This approach allows necessary remote administration while avoiding unsafe public exposure of critical systems. It also supports the principle of least privilege because VPN access does not provide unrestricted access to the entire internal network.

2.3.6 Tailscale VPN Proof-of-Concept

As a practical demonstration of the remote-access VPN concept, a small-scale Tailscale test was conducted. Tailscale was used as a free cost VPN solution to create an authenticated private connection between a manager device and an internal service, without exposing that service directly to the public Internet.

In the test, a local HTTP service was hosted on a Mac using port 8080. An iPhone connected to the same Tailscale network was then able to access the service through the

private Tailscale IP address. This demonstrates that remote access can be achieved through an authenticated VPN tunnel rather than through public port forwarding.

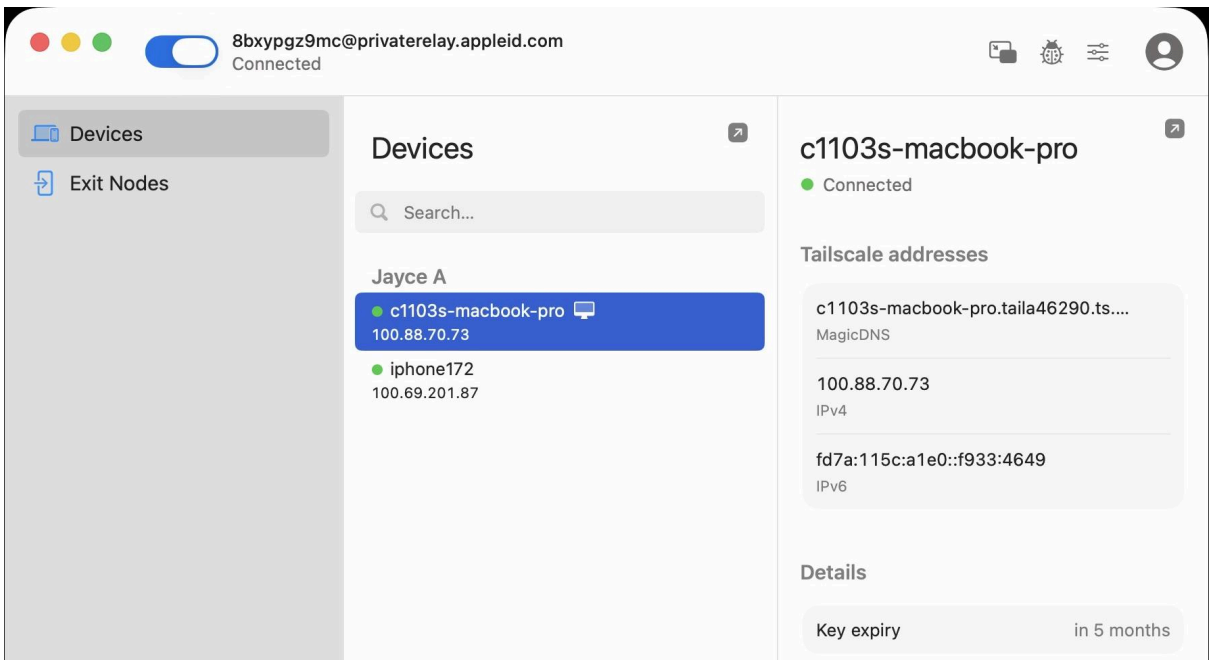


Figure 19. A server was deployed on the Mac using a local HTTP service on port 8080

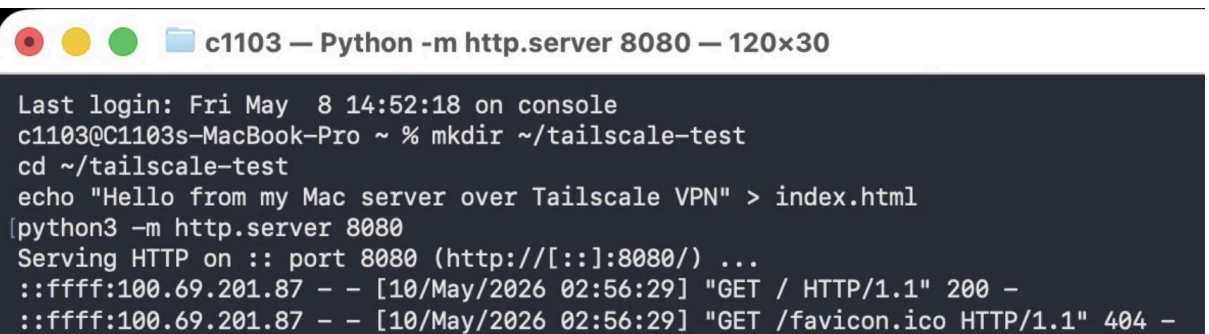
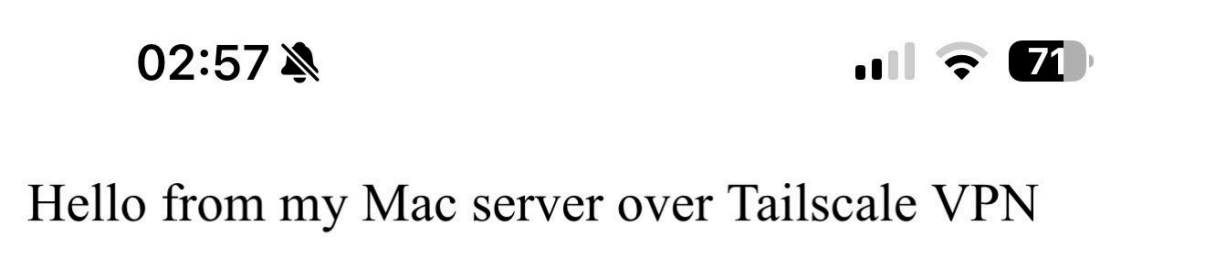


Figure 20. The Mac HTTP server successfully received a request from the iPhone through Tailscale VPN



Hello from my Mac server over Tailscale VPN

Figure 21. The iPhone successfully accessed the Mac server

2.3.8 Suggested Final Policy

For a small community business, the recommended final policy is deliberately simple:

- VLAN10 POS: highly protected, only required local and Internet flows.

- VLAN20 CCTV: cameras to NVR, optional Staff viewing, minimal Internet dependence.
- VLAN30 IoT: high-risk segment, isolated except for specific device functions.
- VLAN40 Staff: Internet access plus a few narrow business exceptions.
- VLAN50 Delivery: Internet only, no internal access.
- VPN: remote-access VPN to the firewall, landing in a dedicated VPN subnet, with access only to the POS Server and NVR.
- Host-level protection should be enabled on the POS Server and NVR to block insecure protocols, restrict access from untrusted VLANs, detect suspicious traffic behaviour, and log security events.

This design is suitable for the scale of the business because it avoids enterprise-level complexity while still addressing the main flat-network problems: unrestricted trust, lateral movement, and unmanaged remote access. The result is a small, practical, and defensible policy set that can be implemented on common small-business firewalls and managed over time with minimal overhead.

2.4 Detect and Respond to Attacks

2.4.1 Why Detection and Response Are Needed

Preventive controls such as attack surface reduction, VLAN segmentation, ACLs, VPN, and host-level protection reduce the likelihood of compromise. However, they cannot guarantee that all the attacks will be prevented. Detection and response therefore provide the visibility layer needed to identify suspicious behaviour, preserve evidence, and contain compromised devices before they can affect critical systems.

In this project, detection and response focus on three main goals: monitoring suspicious traffic between network areas, recording access attempts against critical systems, and responding by blocking or isolating suspicious devices. This creates a complete **defensive chain**: suspicious activity is detected, evidence is recorded, a response action is applied, and the result is verified to confirm that the suspicious device can no longer access sensitive services. In practice, knowing that an attack or suspicious access attempt has occurred is critical, because an undetected compromise may be more damaging than a blocked attack. Detection and response therefore support the overall defence-in-depth strategy by reducing attacker dwell time and helping the store contain incidents quickly.

2.4.2 Practical Monitoring Locations

For Taning Lemon Tea, detection and logging should be placed at the points where suspicious activity is most likely to be observed and where response actions can realistically be applied.

location	Purpose
Firewall/router IDS or IPS	Detects scans, access attempts, suspicious outbound traffic and attacks crossing network boundaries.
Switch mirror/SPAN port sensor	Passively monitor traffic involving POS, CCTV, IoT, staff and delivery networks.
POS host logs	Confirm whether suspicious network activity reached or affected the POS/NVR endpoint.
Firewall logs	Confirm whether traffic was blocked, allowed, repeated or escalated.

2.4.3 Detection and Response Workflow

Once an IDS, firewall, or host-level log generates an alert, the alert should be handled through a staged response process. This ensures that low-risk events are recorded without unnecessary disruption, while repeated or high-risk activity can be investigated, contained, or isolated.

Alerts could be handled in stages:

Level	Trigger	Response
Level 1: Monitor	Single low-risk alert such as one ping or one blocked connection.	Record the event and continue monitoring.
Level 2: Investigate	Repeated scans, SSH/SMB/RDP attempts, or access to POS/NVR services.	Identify the source device, check who owns it, and compare IDS alerts with firewall/POS logs.
Level 3: Contain	Repeated suspicious behaviour or unknown source targeting critical systems.	Add source IP/MAC to the firewall block list or quarantine group.
Level 4: Isolate	Confirmed compromise, malware-like behaviour or continued attacks after blocking.	Disconnect the device, move it to a quarantine network, reset credentials and contact IT support.
Level 5: Recover	POS/NVR affected or business operation disrupted.	Restore from backup, patch systems, rotate passwords and document the incident.

The IDS must connect to an action plan. Seeing an alert is not enough; the store needs a clear response process:

1. IDS alert occurs.
2. Check source IP, destination IP, port, timestamp and alert message.
3. Confirm the event using firewall logs and, where possible, POS host logs.
4. Classify severity and decide whether to monitor, investigate, block or isolate.
5. Apply containment by adding the source to a firewall block/quarantine list.
6. Retest or verify that POS/NVR access is no longer possible from the suspicious source.
7. Record what happened, who responded and what action was taken.

In addition, alert reviews should be scheduled based on risk. High-severity alerts involving the POS system, NVR, VPN, router management interface, or repeated blocked access should be checked as soon as possible. Repeated scans, suspicious IoT or delivery-device behaviour, and recurring denied firewall events can be reviewed weekly. Important logs should be retained for a practical period, such as 30 to 90 days.

2.4.4 Local IDS Simulation

2.4.4.1 Lab Architecture

Direct access to the real store network was not available, so the implementation was completed as a controlled local simulation. To demonstrate the detection and response workflow in a safe environment, a local IDS simulation was conducted.

The simulated risk path was an untrusted or compromised endpoint attempt to discover and access the POS environment.

Role	Simulated device	IP address	Security purpose
Untrusted source	Kali Linux VM	192.168.64.2	Simulates delivery tablet / IoT attacker
Critical asset	Ubuntu VM	192.168.64.3	Simulates POS server and IDS host
Critical services	SSH, HTTP, SMB-like ports	22, 80, 445	Admin, POS web service and file-sharing style target
Containment control	Ubuntu UFW firewall	Host firewall	Blocks suspicious source after IDS detection

The implementation used a lightweight two-VM lab rather than a full production network. Kali generated controlled suspicious traffic. Ubuntu hosted the fake POS service and the Suricata sensor for lab simplicity. In the real store, this response would correspond to adding the suspicious device to a firewall block list, quarantine group, or restricted VLAN. This kept

the test simple, repeatable and safe while still demonstrating real defensive cybersecurity skills.

```

ubuntu@ubuntu:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: enp0s1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 1a:63:23:39:a4:2c brd ff:ff:ff:ff:ff:ff
    inet 192.168.64.3/24 metric 100 brd 192.168.64.255 scope global dynamic enp0s1
        valid_lft 3534sec preferred_lft 3534sec
    inet6 fd47:9380:cd75:ca94:1863:23ff:fe39:a42c/64 scope global dynamic mngtmp
        addr noprefixroute
        valid_lft 2591937sec preferred_lft 604737sec
    inet6 fe80::1863:23ff:fe39:a42c/64 scope link
        valid_lft forever preferred_lft forever
  
```

Figure 22. Ubuntu network interface used for the simulated POS and IDS host

```

(kali@kali)-[~]
$ curl http://192.168.64.3/pos/
Boba Tea Store POS System - Simulated Critical Asset
  
```

Figure 23. Kali accessed the simulated POS page before containment, proving the POS service was reachable before the response action

2.4.4.2 Suricata IDS configuration

Custom Suricata rules were created to generate alerts for ICMP probing, HTTP access to the fake POS web page, SSH attempts, and SMB attempts.

```

alert icmp any any -> any any (msg:"BOBA ALERT: ICMP ping/probing detected"; sid:1001001; rev:1;)
alert tcp any any -> any 80 (msg:"BOBA ALERT: HTTP access to fake POS web server"; content:"/pos"; http_uri; sid:1001002; rev:1;)
alert tcp any any -> any 22 (msg:"BOBA ALERT: SSH access attempt to critical POS host"; sid:1001003; rev:1;)
alert tcp any any -> any 445 (msg:"BOBA ALERT: SMB access attempt to critical POS host"; sid:1001004; rev:1;)
  
```

2.4.4.3 Detection Test: Scanning and Access Attempts

Kali generated controlled test traffic against the Ubuntu POS host. The test included ping probing, service scanning against ports 22, 80 and 445, and HTTP access to the fake POS page. Suricata detected these events and recorded the source IP, destination IP, protocol, destination port, rule ID and alert message.

```
(kali@kali)-[~]
└─$ nmap -sV -p 22,80,445 192.168.64.3
Starting Nmap 7.94 ( https://nmap.org ) at 2026-05-01 07:28 PDT
Nmap scan report for 192.168.64.3
Host is up (0.00036s latency).

PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.9p1 Ubuntu 3ubuntu0.15 (Ubuntu Linux; p
protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.52 ((Ubuntu))
445/tcp   closed microsoft-ds
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://n
map.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.15 seconds
```

Figure 24. Kali generated scan traffic against the simulated POS host

```
ubuntu@ubuntu: ~
05/01/2026-14:27:50.489783  [**] [1:1001001:1] BOBA ALERT: ICMP ping/probing det
ected [**] [Classification: (null)] [Priority: 3] {IPv6-ICMP} fe80:0000:0000:000
0:e8f0:2fff:fe00:113a:143 -> ff02:0000:0000:0000:0000:0000:0000:0016:0
05/01/2026-14:28:28.635235  [**] [1:1001001:1] BOBA ALERT: ICMP ping/probing det
ected [**] [Classification: (null)] [Priority: 3] {ICMP} 192.168.64.2:8 -> 192.1
68.64.3:0
05/01/2026-14:28:28.635820  [**] [1:1001001:1] BOBA ALERT: ICMP ping/probing det
ected [**] [Classification: (null)] [Priority: 3] {ICMP} 192.168.64.3:0 -> 192.1
68.64.2:0
05/01/2026-14:28:54.801896  [**] [1:1001001:1] BOBA ALERT: ICMP ping/probing det
ected [**] [Classification: (null)] [Priority: 3] {IPv6-ICMP} fe80:0000:0000:000
0:fc2:14ff:feda:9e64:135 -> ff02:0000:0000:0000:0000:0001:ff00:113a:0
05/01/2026-14:28:54.802209  [**] [1:1001003:1] BOBA ALERT: SSH access attempt to
critical POS host [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.64.
2:55868 -> 192.168.64.3:22
05/01/2026-14:28:54.802209  [**] [1:1001004:1] BOBA ALERT: SMB access attempt to
critical POS host [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.64.
2:35810 -> 192.168.64.3:445
05/01/2026-14:28:54.829585  [**] [1:1001003:1] BOBA ALERT: SSH access attempt to
critical POS host [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.64.
2:55878 -> 192.168.64.3:22
05/01/2026-14:29:30.174286  [**] [1:1001002:1] BOBA ALERT: HTTP access to fake P
OS web server [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.64.2:595
86 -> 192.168.64.3:80
05/01/2026-14:30:04.540727  [**] [1:1001001:1] BOBA ALERT: ICMP ping/probing det
ected [**] [Classification: (null)] [Priority: 3] {IPv6-ICMP} fe80:0000:0000:000
0:fc2:14ff:feda:9e64:134 -> ff02:0000:0000:0000:0000:0000:0000:0001:0
05/01/2026-14:30:04.551549  [**] [1:1001001:1] BOBA ALERT: ICMP ping/probing det
ected [**] [Classification: (null)] [Priority: 3] {IPv6-ICMP} fe80:0000:0000:000
0:e8f0:2fff:fe00:113a:143 -> ff02:0000:0000:0000:0000:0000:0000:0016:0
05/01/2026-14:30:04.552572  [**] [1:1001001:1] BOBA ALERT: ICMP ping/probing det
ected [**] [Classification: (null)] [Priority: 3] {IPv6-ICMP} fe80:0000:0000:000
0:1863:23ff:fe39:a42c:143 -> ff02:0000:0000:0000:0000:0000:0000:0016:0
```

Figure 25. Suricata fast.log showing BOBA ALERT detections for probing and service access attempts.

```
ubuntu@ubuntu:~$ sudo tail -n 100 /var/log/suricata/eve.json | jq 'select(.event
_type=="alert")'
[
  {
    "timestamp": "2026-05-01T14:36:09.801784+0000",
    "flow_id": 1941581747272696,
    "in_iface": "enp0s1",
    "event_type": "alert",
    "src_ip": "fe80:0000:0000:0000:fc2:14ff:feda:9e64",
    "src_port": 0,
    "dest_ip": "ff02:0000:0000:0000:0000:0000:0000:0001",
    "dest_port": 0,
    "proto": "IPv6-ICMP",
    "icmp_type": 134,
    "icmp_code": 0,
    "alert": {
      "action": "allowed",
      "gid": 1,
      "signature_id": 1001001,
      "rev": 1,
      "signature": "BOBA ALERT: ICMP ping/probing detected",
      "category": "",
      "severity": 3
    },
    "flow": {
      "pkts_toserver": 1,
      "pkts_toclient": 0,
      "bytes_toserver": 142,

```

Figure 26. Suricata eve.json output showing structured IDS alert evidence

2.4.4.4 Detection Test: Response Test: Blocking Suspicious Source

After Suricata detected suspicious behaviour from 192.168.64.2, the source IP was blocked using Ubuntu Firewall. In a real store, this represents adding the suspicious endpoint to a firewall quarantine list or moving it into a restricted VLAN.

```
ubuntu@ubuntu:~$ sudo ufw status numbered
Status: active

      To      Action      From
      --      -
[ 1] Anywhere  DENY IN    192.168.64.2
```

Figure 27. UFW rule blocking the suspicious Kali source IP

```
(kali@kali)~$ nmap -sV -p 22,80,445 192.168.64.3
Starting Nmap 7.94 ( https://nmap.org ) at 2026-05-01 07:37 PDT
Note: Host seems down. If it is really up, but blocking our ping probes, try
-Pn
Nmap done: 1 IP address (0 hosts up) scanned in 3.06 seconds

(kali@kali)~$ curl --connect-timeout 5 http://192.168.64.3/pos/
curl: (28) Failed to connect to 192.168.64.3 port 80 after 5003 ms: Timeout w
as reached
```

Figure 28. After containment, HTTP access to the simulated POS page timed out

```
(kali@kali)~$ nmap -Pn -p 22,80,445 192.168.64.3
Starting Nmap 7.94 ( https://nmap.org ) at 2026-05-01 07:40 PDT
Nmap scan report for 192.168.64.3
Host is up.

PORT      STATE      SERVICE
22/tcp    filtered  ssh
80/tcp    filtered  http
445/tcp    filtered  microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 3.02 seconds
```

Figure 29. Nmap -Pn showed ports 22, 80 and 445 as filtered after containment

The filtered result is important. It shows that the host still existed, but the critical POS-facing services were no longer reachable from the suspicious device. This demonstrates containment rather than just passive monitoring.

2.4.4.5 Final Test: Unauthorised SSH Access Attempt

A second test using an unauthorized SSH attempt confirmed that administrative access attempts could also be detected and contained.

```
(kali@kali)~$ ssh fakeuser@192.168.64.3
kankiumai
fakepass
bruteforce
login
```

Figure 30. Kali simulated an unauthorised SSH access attempt

```

(kali@kali)~$ nmap -Pn -p 22 192.168.64.3
Starting Nmap 7.94 ( https://nmap.org ) at 2026-05-01 07:54 PDT
Nmap scan report for 192.168.64.3
Host is up.

PORT      STATE      SERVICE
22/tcp    filtered  ssh

Nmap done: 1 IP address (1 host up) scanned in 2.02 seconds

```

Figure 31. Follow-up scan showed SSH port 22 as filtered after the response action

2.4.4.6 Evidence Test Matrix

Test	Purpose	Result
Baseline	Confirm POS service was reachable before containment	Reachable
Detection	Generate scan/access attempts from Kali	Suricata alerts recorded
Response	Block suspicious source using UFW	HTTP timeout and ports filtered
Verification	Retest access after containment	Critical services no longer reachable

2.4.5 Practical Deployment Options

The detection and response design can be implemented at different cost levels depending on the store's budget and technical support.

For a **low-cost deployment**, the store can rely on the existing router or firewall logs, enable a higher firewall or IDS/IPS security level if supported, and review POS/NVR host logs for failed login attempts or suspicious access. The store should also maintain a simple incident response checklist so that suspicious devices can be blocked, isolated, or escalated when needed. If an unused spare computer is available, Suricata can be deployed in detection-only mode as a basic monitoring sensor.

For a **moderate-cost deployment**, which is the most realistic option for this store, the business could upgrade to a small-business firewall or router such as pfSense, OPNsense, UniFi Gateway, MikroTik, or a managed OpenWRT device. These platforms can provide stronger firewall logging, IDS/IPS capability using tools such as Suricata or Snort, VPN support, and firewall block lists for containment. A managed switch can also be used to support VLAN segmentation and, where needed, mirror selected traffic for monitoring.

For a **higher-investment deployment**, the store could use a dedicated IDS sensor, centralised log management such as Wazuh or another SIEM, POS host telemetry, and automated response actions. For example, repeated high-confidence alerts from an IoT or Delivery device could automatically trigger quarantine rules. This option provides stronger investigation and faster response, but it also requires higher cost, technical maintenance, or outsourced IT support.

Overall, the moderate-cost option is the most practical long-term recommendation. It provides real IDS/IPS capability, useful logging, VPN integration, and a containment process without requiring the store to operate a full enterprise security operations centre.

Justification

All implemented solutions are aligned with key security principles, including Defence in Depth, the Principle of Least Privilege, Minimising the Attack Surface, and building a practical Detection and Response model. These principles ensure that the proposed security design not only prevents unauthorised access and reduces exposure, but also provides the ability to identify suspicious activity and respond quickly when prevention controls are bypassed. Together, the controls create a layered, realistic, and manageable security approach suitable for Taming Lemon Tea as a small business environment.

3.1 Defense in Depth

The proposed design follows a defence-in-depth strategy, where multiple layers of security controls are applied to protect critical assets.

- Layer 1: Network segmentation (VLAN) limits lateral movement within the network.
- Layer 2: Access control mechanisms (ACL and firewall rules) regulate communication between VLANs and enforce security boundaries.
- Layer 3: Host-level protection ensures that critical systems such as the POS server and NVR remain protected even if network-level controls are bypassed.

This layered approach ensures that the failure of one control does not lead to a complete compromise of the system.

3.2 Principle of Least Privilege

The principle of least privilege is enforced by restricting access to only what is necessary for each device or user. Inter-VLAN communication is controlled using ACL and firewall rules, ensuring that only authorized devices can access critical systems. Additionally, administrative interfaces are limited to trusted devices, and VPN is used to ensure that only authenticated users can access sensitive resources. These measures reduce the risk of unauthorized access and limit the potential impact of compromised devices.

3.3 Minimize Attack Surface

The attack surface is minimized by reducing both external and internal entry points. Externally, unnecessary ports are closed and UPnP is disabled, preventing unintended exposure of internal services. Internally, guest WiFi is used to isolate untrusted users from the main network, limiting access to sensitive systems. At the device level, shared systems are configured to require user logout, and USB access is restricted to prevent the introduction of malicious software. These measures collectively reduce the likelihood of successful initial access.

3.4 Build a Detection and Response Model

For Tanning Lemon Tea, detection and response are especially important because the critical systems directly support daily business operations. Unlike large enterprises, the store's detection and response should focus on automation and lightweight design. A suitable approach is lightweight and practical monitoring through the router/firewall, IDS/IPS features where available, firewall logs, VPN logs, and host-level logs. The response process should also remain simple and actionable. Suspicious devices can be blocked through firewall rules, added to a quarantine group, moved to a restricted VLAN, or disconnected if compromise is confirmed. This lightweight detection and response model is suitable for a small business because it improves visibility and containment capability without requiring enterprise-level cost or staffing.

Impact

4.1 Security Impact

The implemented security enhancements significantly improve the overall security posture by reducing both the likelihood and impact of potential attacks.

Firstly, the attack surface is reduced through measures such as closing unnecessary ports, disabling UPnP, isolating untrusted devices, enforcing screen lock, and restricting USB storage. This limits the number of entry points available to attackers.

Secondly, VLAN segmentation and ACL/firewall rules reduce lateral movement within the network. Even if an attacker gains access to one segment, high-risk devices such as IoT or delivery tablets are restricted from directly reaching critical systems such as the POS Server or NVR.

Finally, VPN, host-level protection, and detection/response controls further protect critical assets. VPN avoids unsafe public exposure of remote access services, while IDS/firewall logs and response procedures help detect suspicious activity, record evidence, and block or isolate compromised devices before they cause wider business impact.

4.2 Operational Impact

The implementation of these security measures introduces additional operational complexity. Network segmentation, ACLs, VPN access, logging, and IDS/IPS features require careful configuration and periodic review. Misconfiguration may disrupt WiFi, POS, CCTV, delivery tablets, or remote access, so changes should be tested and documented before deployment.

However, this complexity is manageable if the implementation is staged. Low-disruption controls such as password changes, UPnP disablement, Guest WiFi isolation, basic logging, and host-level protection can be applied first, while VLANs, IDS/IPS, and advanced firewall rules can be introduced when budget and technical support allow.

4.3 Usability Impact

The security enhancements may introduce minor usability challenges for users. Staff or delivery devices may be restricted from accessing certain network resources, and managers may need to use VPN for remote access to critical systems. Logging and response procedures may also require staff or the owner to review alerts or contact IT support when suspicious activity occurs.

However, these limitations are acceptable because they protect sensitive systems and reduce the risk of payment disruption, surveillance exposure, or data loss. Overall, the design balances security with usability by prioritising low-cost and low-disruption controls for a small community business.

Conclusion

5.1 Comparison of No Implementation, Ideal Implementation, and Real-World Implementation

This section compares three possible security states for Taming Lemon Tea: the current network without implementation, the ideal security design, and a practical real-world implementation suitable for a small community business. The comparison is based on the observed risks from the site assessment and the practical improvement summary provided to the store owner. At the time of writing, the owner has not confirmed which actions will be implemented, so the real-world implementation described below should be understood as a recommended practical plan rather than a confirmed deployment.

5.1.1 Without Implementation

Without implementing the proposed security enhancements, the store remains exposed to several avoidable risks. The original environment uses a flat network, this increases the risk

that a compromised or unauthorized device could scan the internal network and attempt to access critical systems such as the POS server, NVR, or router management interface.

The current setup also includes risks such as weak WiFi access control, router management using default credentials, possible UPnP or public-facing port exposure, and insufficient physical access protection around staff-area devices. These weaknesses do not mean the store has already been attacked, but they increase the likelihood of payment disruption, surveillance exposure, unauthorized router changes, network outage, or data loss.

In this state, the identified attack paths still exist. An attacker or compromised device could potentially enter through WiFi, abuse weak router administration, move laterally across the flat network, or access exposed services if port forwarding or UPnP is enabled.

5.1.2 Ideally Implementation

The ideal implementation would use business-grade network infrastructure to enforce a stronger layered security design. The network would be segmented by function, separating POS/payment systems, CCTV/NVR, staff devices, guest or delivery devices, IoT devices, and management access.

In this design, VLANs would prevent unnecessary communication between device groups, while ACL and firewall rules would enforce least privilege between VLANs. Remote access to sensitive systems such as the POS server or NVR would be performed through VPN rather than direct public exposure. IDS/IPS, firewall logs, VPN logs, and host-level logs would be used to detect suspicious activity and support response actions such as blocking or isolating compromised devices.

This ideal design provides the strongest security posture because it directly addresses initial access, internal spread, access control, detection, response, and recovery. However, it requires higher cost, technical configuration, and ongoing maintenance. For a small shop without dedicated IT support, the ideal design may not be immediately realistic.

5.1.1 Real-World-Implementation

The real-world implementation should focus on low-cost, low-disruption improvements first. These actions are more practical for a small community business and can reduce risk quickly without requiring a full enterprise network redesign. The first recommended steps include changing the router administrator password, changing the weak WiFi password, removing visibly posted plaintext passwords, disabling UPnP and unnecessary port forwarding, enabling Guest WiFi for staff phones, delivery tablets, and temporary or high-risk devices, and adding login protection to the monitoring computer.

In this practical version, Guest WiFi acts as a basic segmentation method when full VLAN infrastructure is not available. Staff phones, delivery tablets, and other higher-risk devices can be moved to Guest WiFi, while POS, NVR, CCTV, and other critical systems remain on

the internal business network. This does not provide the same level of control as VLANs and ACLs, but it reduces the risk of high-risk devices directly interacting with critical systems.

For longer-term improvement, the store could follow a staged roadmap. The basic option is to use Guest WiFi isolation to separate staff and high-risk devices from POS and CCTV. The advanced option is to deploy a business-grade router, managed switch, and business-grade access points. A low-budget technical option would be to use a software router, managed switch, and multiple APs or SSIDs, but this requires careful technical configuration.

Overall, the real-world implementation does not remove every possible risk path, but it significantly reduces the easiest and most likely attack paths. The real-world implementation is not the strongest possible solution, but it is the most practical starting point.

5.2 Reflection

This project showed that cybersecurity recommendations must be realistic, not only technically correct. From a technical perspective, the proposed ideal design using VLANs, ACLs, VPN, logging, and IDS/IPS would significantly improve the security posture of the store. However, the project also highlighted the gap between theoretical security design and real-world implementation.

5.2.1 Strength: Attacker-Minded Threat Modeling

A strength of this project is that the security design was developed from an attacker-minded perspective. Instead of listing generic controls, the assessment first considered how an attacker could realistically enter the network, move laterally, and target critical assets such as the POS server, NVR, and router management interface. This made the proposed mitigations more focused, because each control was designed to interrupt a specific stage of the attack path. For example, disabling UPnP and reducing exposed services helps prevent external entry, Guest WiFi and VLAN segmentation reduce internal spread, ACL and VPN rules restrict access to critical systems, and monitoring and response provide visibility if suspicious activity still occurs.

5.2.2 Challenge: Real-World Implementation Needs Balance

Another key lesson is that real-world deployment is not about achieving the maximum possible security at all costs. Instead, it requires balancing security, cost, usability, technical complexity, and business continuity. For a small community business, an overly complex solution may introduce new risks if it is difficult to configure, maintain, or recover from. Therefore, the practical goal is to identify which risks are acceptable, which risks can be reduced with low-disruption controls, and which security boundaries must not be crossed, such as exposing POS, NVR, or router management services directly to the internet.

5.2.3 Challenge: Communication with Non-Technical Owner

Communication is also a critical part of cybersecurity work. It is not enough to tell the store owner what should be changed; the recommendations must also explain why cybersecurity

matters in business terms. For example, risks should be connected to possible payment disruption, surveillance exposure, network outage, or unauthorized changes to business systems. The fact that the owner had not responded at the time of writing suggests that the recommendations may still have been difficult to assess, despite being simplified. This highlights the need to communicate technical risks in a clearer and more actionable way for non-technical stakeholders.

5.2.4 Improvement: Plan More For Post-Compromise Response

The project also reinforced that defenders should not assume that a defensive system will be unbreakable. Any real deployment should be designed with the assumption that some controls may fail or be bypassed. This means that detection, logging, incident response, backup, and recovery planning are essential parts of the security design. In this project, more attention could have been given earlier to post-compromise response, such as what the store should do if a POS device, NVR, staff phone, or delivery tablet is suspected to be compromised.

5.2.5 Broader Observation: OEM Vendors Matter For Small-Business Security

Finally, the project highlighted the important role of OEM vendors and service providers in small-business security. For many small businesses, POS, NVR, router, and CCTV vendors are the closest point of contact to professional IT support. These vendors should provide timely security updates, clearly notify users about critical vulnerabilities, and make updates easy to apply. Remote maintenance should also be implemented through secure methods such as VPN or vendor-managed secure support, rather than unsafe public port forwarding. For small businesses without dedicated IT staff, vendor security practices can directly affect the overall security posture.

Overall, this project demonstrates that effective cybersecurity is not only about applying advanced controls. It requires understanding realistic attack paths, choosing controls that match the business environment, communicating risk clearly, planning for failure, and balancing protection with cost and operational stability. For Tanning Lemon Tea, the most realistic path is to begin with simple, low-disruption hardening actions, then gradually move toward stronger segmentation, access control, monitoring, and recovery planning as budget and technical support allow.

References

- Australian Cyber Security Centre. (2023). *Strategies to mitigate cyber security incidents*. Australian Signals Directorate.
<https://www.cyber.gov.au/resources-business-and-government/essential-cyber-security/strategies-mitigate-cyber-security-incidents>
- Canonical. (2025). *Firewalls and UFW*. Ubuntu Server documentation.
<https://documentation.ubuntu.com/server/how-to/security/firewalls/>
- Cloudflare. (n.d.). *What is network segmentation?*
<https://www.cloudflare.com/learning/security/glossary/network-segmentation/>
- National Institute of Standards and Technology. (2007). *Guide to intrusion detection and prevention systems* (NIST Special Publication 800-94). U.S. Department of Commerce.
<https://csrc.nist.gov/pubs/sp/800/94/final>
- National Institute of Standards and Technology. (2020). *Security and privacy controls for information systems and organizations* (NIST Special Publication 800-53 Rev. 5). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.SP.800-53r5>
- National Institute of Standards and Technology. (2020). *Zero trust architecture* (NIST Special Publication 800-207). U.S. Department of Commerce.
<https://doi.org/10.6028/NIST.SP.800-207>
- National Institute of Standards and Technology. (2025). *Incident response recommendations and considerations for cybersecurity risk management* (NIST Special Publication 800-61 Rev. 3). U.S. Department of Commerce. <https://csrc.nist.gov/pubs/sp/800/61/r3/final>
- Open Information Security Foundation. (2026). *EVE JSON output*. Suricata documentation.
<https://docs.suricata.io/en/latest/output/eve/eve-json-output.html>
- PCI Security Standards Council. (2024). *PCI DSS v4.0.1 requirement 10: Log and monitor all access to system components and cardholder data*. <https://www.pcisecuritystandards.org/>